Politique de sécurité des systèmes d'information – Orséa Banque

Cette politique fixe les règles de sécurité que tout collaborateur et prestataire d'Orséa Banque doit appliquer. Elle découle de l'analyse de risques EBIOS RM (AR_01) et de la Déclaration d'applicabilité ISO 27001 (AUD_01).

1. Objet, périmètre et références

Cette PSSI définit les objectifs et les règles de sécurité applicables au SMSI « Plateforme bancaire en ligne » d'Orséa Banque.

Périmètre : application mobile et site client, core banking, paiements par carte et virements, ouverture de compte (KYC), support client, et l'infrastructure hébergée chez AWS. Les fonctions RH et comptables sont hors périmètre du SMSI, mais leurs accès au SI restent soumis à cette politique.

Public concerné : tous les collaborateurs, stagiaires, alternants et prestataires ayant accès aux informations ou au SI d'Orséa.

Objectifs de sécurité

- Protéger les fonds et les données des clients contre la fraude et la divulgation.
- Garantir la disponibilité des services bancaires essentiels (besoin D4).
- Respecter les obligations légales et réglementaires de l'établissement.
- Maîtriser les risques liés aux prestataires TIC.

Références : ISO/IEC 27001:2022 et ISO/IEC 27002:2022, guide EBIOS Risk Manager (ANSSI), règlement (UE) 2022/2554 (DORA), RGPD, directive DSP2, dispositif LCB-FT du Code monétaire et financier.

2. Engagement de la direction et organisation

Le comité exécutif (COMEX) approuve cette politique, alloue les ressources nécessaires et porte la responsabilité finale du risque TIC, conformément à l'article 5 de DORA.

Rôle	Responsabilités principales
COMEX	Approuve la PSSI, le plan de traitement et le budget ; arbitre l'acceptation des risques résiduels

Rôle	Responsabilités principales
RSSI	Pilote le SMSI, l'analyse de risques et le plan de traitement ; rend compte au COMEX chaque trimestre
DSI	Met en œuvre les mesures techniques (MFA, sauvegardes, changements)
Directeur de la conformité	Pilote le dispositif LCB-FT, les déclarations Tracfin et la conformité réglementaire
Délégué à la protection des données (DPO)	Veille au respect du RGPD
Propriétaires des risques	Approuvent le traitement de leurs risques et acceptent les risques résiduels
Collaborateurs et prestataires	Appliquent la PSSI et signalent tout incident

Le RSSI est rattaché à la direction générale et indépendant de la DSI, pour éviter qu'une même personne décide et contrôle la sécurité (contrôles 5.2, 5.3, 5.4).

3. Gestion des risques

Orséa apprécie ses risques avec la méthode EBIOS Risk Manager, sur une matrice 4 × 4 (gravité G1 à G4, vraisemblance V1 à V4).

- Un risque de niveau élevé ne peut pas être accepté en l'état : il doit être réduit, transféré ou évité.
- Chaque risque a un propriétaire métier qui approuve son traitement et accepte formellement le risque résiduel.
- Le cycle stratégique (ateliers 1 à 3) est revu chaque année ; le cycle opérationnel (ateliers 4 et 5) tous les six mois.
- Une nouvelle analyse est obligatoire après un incident majeur, un changement significatif du SI ou l'arrivée d'un prestataire TIC critique.
- L'avancement du plan de traitement est revu chaque trimestre en comité sécurité.

4. Actifs et classification des informations

Toute information et tout actif du périmètre figure dans un inventaire tenu à jour, avec un propriétaire désigné (contrôles 5.9 à 5.13).

Niveau	Exemples	Règles
Public	Tarifs, offres commerciales	Diffusion libre
Interne	Procédures, organigramme	Collaborateurs et prestataires autorisés
Confidentiel	Données clients, contrats prestataires	Besoin d'en connaître, chiffrement en transit et au repos
Secret	Dossiers LCB-FT, déclarations Tracfin, clés cryptographiques	Liste nominative, journalisation de chaque accès

- Les documents Confidentiel et Secret portent leur niveau de classification.
- Le matériel et les accès sont restitués le dernier jour d'un collaborateur ou d'un prestataire.
- L'usage du SI est régi par une charte que chaque utilisateur signe à son arrivée.

5. Contrôle d'accès et gestion des identités

L'accès aux informations repose sur le besoin d'en connaître et le moindre privilège (contrôles 5.15 à 5.18, 8.2, 8.3, 8.5).

- Chaque compte est nominatif ; les comptes partagés sont interdits.
- Les arrivées, mobilités et départs déclenchent la création, la modification ou la suppression des droits sous 24 heures.
- Les droits sont revus chaque trimestre par les managers et le RSSI (M_22).
- Les agents du support n'accèdent qu'aux données nécessaires à la demande en cours (M_06).
- Les opérations sensibles (déblocage de plafond, modification de coordonnées par un agent) exigent une validation à quatre yeux (M_22).
- L'authentification multifacteur est obligatoire pour les comptes à privilèges, les accès distants et les accès prestataires (M_12).
- Les clients s'authentifient avec une authentification forte conforme à la DSP2 (M_01).
- Les mots de passe font au moins 12 caractères et ne sont jamais partagés ni réutilisés.

6. Sécurité liée aux ressources humaines

Les collaborateurs sont la première ligne de défense et un risque identifié (initié malveillant, CA_05) ; ces règles couvrent les contrôles 6.1 à 6.8.

- Les candidats aux postes sensibles (support, conformité, administration du SI) font l'objet de vérifications proportionnées avant l'embauche.
- Le contrat de travail et les contrats prestataires incluent une clause de confidentialité qui survit à la fin de la relation.
- Chaque collaborateur suit une sensibilisation à son arrivée puis chaque année ; des simulations de phishing sont menées au moins quatre fois par an (M_15).
- Le télétravail se fait uniquement sur un poste fourni par Orséa, avec accès distant sécurisé et MFA.
- Tout collaborateur signale sans délai un message suspect ou une anomalie à l'adresse de signalement sécurité.
- Une violation de la PSSI peut entraîner une sanction disciplinaire (voir section 13).

7. Sécurité physique des locaux

Orséa n'héberge aucun serveur : la sécurité physique des centres de données relève d'AWS et est encadrée par contrat (contrôle 5.23). Cette section couvre les bureaux.

- L'accès aux bureaux se fait par badge nominatif ; les visiteurs sont enregistrés et accompagnés.
- Les zones du support client et de la conformité sont à accès restreint.
- Bureau propre et écran verrouillé : aucun document Confidentiel laissé sans surveillance, verrouillage automatique des postes après 5 minutes.
- Les supports amovibles (clés USB) sont bloqués par défaut sur les postes.
- Le matériel en fin de vie est effacé de manière sécurisée ou détruit, avec un certificat.

Les contrôles 7.8, 7.11 et 7.12 sont exclus de la SoA, faute d'infrastructure hébergée dans les locaux.

8. Exploitation et protection du SI

Ces règles visent d'abord le rançongiciel (CA_03, CA_04) et couvrent les contrôles 8.1, 8.7 à 8.9, 8.13 à 8.17.

Postes et serveurs

- Tous les postes et serveurs disposent d'un EDR supervisé 24 h/24 par un SOC (M_14).
- Les configurations de référence (postes, comptes AWS) sont définies et contrôlées.
- Les correctifs critiques sont appliqués sous 7 jours, les autres sous 30 jours ; un scan de vulnérabilités est réalisé chaque mois.

Sauvegardes

- Le core banking et les données clients sont sauvegardés chaque jour sur un stockage isolé et immuable (M_13).
- Une restauration est testée chaque trimestre ; le résultat est remonté en comité sécurité.

Journalisation et surveillance

- Les actions des administrateurs, des agents du support et des prestataires sont journalisées (M_07, M_23).
- Les journaux sont horodatés sur une source de temps commune et conservés au moins 1 an, 5 ans pour ceux liés à la LCB-FT.
- Les connexions et transactions inhabituelles déclenchent une alerte (M_04, M_19).

9. Réseaux, cryptographie et cloud

Le SI d'Orséa est hébergé chez AWS ; Orséa reste responsable de la configuration et des accès, AWS de l'infrastructure physique (responsabilité partagée, contrôles 5.23, 8.20 à 8.24).

- Les environnements de production, de préproduction et de développement sont cloisonnés dans des réseaux distincts.
- Le core banking est isolé des postes utilisateurs ; seuls les flux nécessaires sont autorisés.
- La navigation web des collaborateurs est filtrée pour bloquer les sites malveillants.
- Les données Confidentiel et Secret sont chiffrées en transit (TLS 1.2 minimum) et au repos.
- Les clés de chiffrement sont gérées dans un service dédié et leur accès est journalisé.
- Toute utilisation d'un nouveau service cloud est validée par le RSSI avant mise en service.

10. Développement et gestion des changements

L'application mobile est exposée à Internet et le core banking dépend d'un éditeur : tout changement passe par un processus contrôlé (contrôles 8.25 à 8.33).

- La sécurité est intégrée dès la conception de chaque projet ; le RSSI valide les projets qui touchent des données Confidentiel.
- Le code suit des règles de développement sécurisé et passe une revue avant fusion ; l'accès au code source est limité aux développeurs habilités.

- L'application intègre des fonctions anti-fraude : alertes de phishing, délai de 24 h avant le premier virement vers un nouveau bénéficiaire, validation des changements de coordonnées (M_02, M_03, M_05).
- Toute mise à jour, y compris celles de l'éditeur du core banking, est testée en préproduction avant la production (M_10).
- Aucune donnée client réelle n'est utilisée en test sans masquage.
- Chaque changement en production est approuvé, tracé et réversible.

11. Fournisseurs et prestataires TIC

Orséa dépend de prestataires critiques : éditeur du core banking, processeur de paiement, AWS, prestataire KYC et prestataire de support. Ces règles appliquent les articles 28 à 30 de DORA et les contrôles 5.19 à 5.23.

- Chaque prestataire TIC est évalué avant contractualisation, selon la criticité du service rendu.
- Les contrats avec les prestataires critiques contiennent au minimum les clauses de l'article 30 de DORA : niveaux de service, localisation des données, notification des incidents, droit d'audit, assistance en cas d'incident et conditions de sortie (M_08, M_09).
- Les prestataires sont soumis à la confidentialité et à cette PSSI pour les accès qu'ils obtiennent.
- Le registre d'information des prestataires TIC est tenu à jour par les Achats et transmis au régulateur sur demande.
- Les prestataires critiques sont revus au moins une fois par an ; une stratégie de sortie est documentée pour chacun.

12. Incidents, crise et continuité d'activité

Orséa détecte, qualifie et traite ses incidents selon un processus unique, conforme aux articles 17 à 19 de DORA (contrôles 5.24 à 5.30, M_16).

1. **Détection** : alerte du SOC, signalement d'un collaborateur, d'un client ou d'un prestataire.
2. **Qualification** : le RSSI classe l'incident selon les critères DORA (clients touchés, durée, impact financier, données concernées).
3. **Réponse** : confinement, éradication et restauration, avec conservation des preuves.
4. **Notification** : un incident majeur est notifié à l'ACPR dans les délais réglementaires ; une violation de données personnelles à la CNIL sous 72 heures.

5. **Retour d'expérience** : chaque incident majeur donne lieu à un bilan qui alimente l'analyse de risques.

Une cellule de crise (direction générale, RSSI, DSI, conformité, communication) est activée pour tout incident majeur ; un exercice de crise a lieu au moins une fois par an. Les plans de continuité fixent pour les services essentiels une durée maximale d'interruption et une perte de données maximale admissibles, validées par le COMEX.

13. Conformité, contrôle et sanctions

Orséa respecte ses obligations légales et vérifie régulièrement l'application de cette politique (contrôles 5.31 à 5.36).

- Le directeur de la conformité tient à jour la liste des exigences applicables : DORA, RGPD, DSP2, LCB-FT, exigences de l'ACPR.
- Les opérations suspectes font l'objet d'une déclaration de soupçon à Tracfin (M_19).
- Le SMSI est audité en interne chaque année par une personne indépendante de l'activité contrôlée (clause 9.2).
- Les tests de résilience exigés par DORA, y compris les tests de pénétration fondés sur la menace (TLPT) lorsque l'établissement y est soumis, sont encadrés pour ne pas perturber la production.
- Le COMEX réalise une revue de direction du SMSI chaque année (clause 9.3).
- Tout manquement à cette politique peut entraîner des sanctions disciplinaires pour les collaborateurs, et des pénalités ou une résiliation pour les prestataires, sans préjudice de poursuites.

14. Correspondance PSSI – SoA – mesures

Chaque section de la PSSI couvre des contrôles de l'Annexe A ; les mesures M_xx sont détaillées dans le plan de traitement.

Section	Contrôles Annexe A	Mesures	Risques
2. Organisation	5.1 à 5.4	—	Tous
3. Gestion des risques	5.1, clauses 6.1 et 8.2	Cadre de suivi AR_01	Tous
4. Actifs et classification	5.9 à 5.14	—	CA_05

Section	Contrôles Annexe A	Mesures	Risques
5. Accès et identités	5.15 à 5.18, 8.2, 8.3, 8.5	M_01, M_06, M_12, M_22	CA_01, CA_03 à CA_05, CA_07
6. Ressources humaines	6.1 à 6.8	M_15	CA_03, CA_05
7. Sécurité physique	7.1 à 7.14 (sauf 7.8, 7.11, 7.12)	—	CA_05
8. Exploitation	8.1, 8.7 à 8.9, 8.13 à 8.17	M_04, M_07, M_13, M_14, M_19, M_23	CA_01, CA_03 à CA_07
9. Réseaux, crypto, cloud	5.23, 8.20 à 8.24	—	CA_03, CA_04
10. Développement	8.25 à 8.33	M_02, M_03, M_05, M_10	CA_01, CA_04, CA_07
11. Fournisseurs	5.19 à 5.23	M_08, M_09	CA_02, CA_04, CA_05
12. Incidents et continuité	5.24 à 5.30	M_13, M_16, M_21	CA_01 à CA_04
13. Conformité	5.31 à 5.36	M_17, M_18, M_19, M_20	CA_05 à CA_07

Une fois cette PSSI approuvée, les contrôles marqués « PSSI (à rédiger) » dans la SoA passent de Non compliant à Partially compliant : la règle existe, sa mise en œuvre reste à vérifier.

15. Validation et révision

Cette PSSI est revue au moins une fois par an par le RSSI, ainsi qu'après un incident majeur, une évolution réglementaire ou un changement significatif du SI. Chaque nouvelle version est approuvée par le COMEX puis communiquée à tous les collaborateurs et prestataires.

Version	Date	Auteur	Modification	Approbation
0.1	15/10/2026	RSSI	Création, à partir de l'analyse EBIOS RM AR_01 et de la SoA AUD_01	En attente du COMEX